PassNi 단일인증 API 가이드

v2.0

㈜유비앤티스랩

UbiNtisLab ⓒ 2024

Revision History

변경번호	변경날짜	내용	작성자
1.0	2024.03.07	제정	함정식

1. Pass-Ni 단일인증 API 개발가이드

PassNi SSO 단일인증 서비스를 위해서는 아래 가이드 내용을 바탕으로 로그인 처리에 대한 개발을 필요로 합니다.
로그인 처리에 대한 개발은 각 응용시스템 개발사 또는 유지보수 담당사에서 확인하시여 진행해주시기 바랍니다.

1.1 단일인증 사용 신청

- 단일인증 서비스 사용을 위한 신청을 정보전산팀으로 요청하시기 바랍니다.
- 단일인증 서비스를 위한 SSO서버에서 필요로 하는 정보는 다음과 같습니다.

◎ 신청 정보

시스템명	*샘플시스템*
서비스 URL	*https://sample.kaist.ac.kr/sp*
로그인 처리 URL	*https://sample.kaist.ac.kr/sp/newLoginProc.do*

1.2 통합로그인 화면 호출

- 단일인증을 위한 통합로그인 화면으로 링크를 변경 해야 합니다.

◎ Request

연동URL	개발 : https://ssodev.kaist.ac.kr/auth/user/single/login/authorize 운영 : https://sso.kaist.ac.kr/auth/user/single/login/authorize		
전송 Data / 전송 Method		POST 방식	
Parameter Name	**Type**	**Required**	**Parameter Contents**
client_id	String	O	기관에서 전달받은 시스템 ID
redirect_uri	String	O	등록된 시스템 redirect URL정보
state	String	O	시스템에서 생성한 랜덤 값 (CSRF 방지용)
nonce	String	O	시스템에서 생성한 랜덤 값 (Replay Attack 방지용)
샘플 코드(예시)			

```
<%
    // 단일인증 연동시스템 아이디
    String client_id = "single-auth-test";
    // 단일인증 로그인 페이지 URL
    String server_app_url = "https://ssodev.kaist.ac.kr/auth/user/single/login/authorize";
    // 단일인증 완료 후 리턴 URI( SSO 관리자 페이지에 등록되어 있는 URI )
    String redirect_uri = "https://단일인증시스템Domain/sample/singleAuth.jsp";
    // 단일인증 완료 후 전달되는 값, CSRF 방지
    String state = "random1";
    // 사용자 정보 조회 시 전달되는 값, Replay Attack 방지
    String nonce = "random2";

    session.setAttribute( "state", state );
    session.setAttribute( "nonce", nonce );


%>
 <script type="text/javascript">

 var client_id = '<%=client_id%>';
 var server_url = '<%=server_app_url%>';
 var redirect_uri = '<%=redirect_uri%>';
 var state = '<%=state%>';
 var nonce = '<%=nonce%>';

 function fnLogin() {
     $('#loginForm').attr('action', server_url).submit();
 }

 </script>

 </head>

 <body>

     <form name="loginForm" id="loginForm" method="post" action="">
         <input type="hidden" id="client_id" name="client_id" value="<%=client_id%>" />
         <input type="hidden" id="redirect_uri" name="redirect_uri" value="<%=redirect_uri%>" />
         <input type="hidden" id="state" name="state" value="<%=state%>" />
         <input type="hidden" id="nonce" name="nonce" value="<%=nonce%>" />
     </form>
```

◎ Response

전송 Data / 전송 Method		POST 방식
Parameter Name	**Type**	**Parameter Contents**
state	String	로그인 요청시 생성한 랜덤값 (CSRF 방지용)
code	String	사용자 정보 요청을 위한 일회성 코드값

1.3 사용자 정보 요청 API

- 단일인증 서비스 신청시 로그인 처리 URL에서 해당 API를 적용하여 개발 하시기 바랍니다.

◎ **Request**

연동URL	개발 : https://ssodev.kaist.ac.kr/auth/api/single/auth 운영 : https://sso.kaist.ac.kr/auth/api/single/auth		
전송 Data / 전송 Method		POST 방식	
Header		"Content-Type", "application/x-www-form-urlencoded;charset=utf-8"	
Parameter Name	**Type**	**Required**	**Parameter Contents**
client_id	String	O	기관에서 전달받은 시스템 ID
client_secret	String	O	기관에서 전달받은 시스템 식별Key
code	String	O	SSO서버로 부터 전달 받은 코드값
redirect_uri	String	O	등록된 시스템 redirect URL정보

샘플 코드(예시)

```
// 단일인증 연동시스템 아이디 (기관에서 발급된 시스템 아이디를 입력)
String client_id = "single-auth-test";
// 단일인증 연동시스템 식별키 (기관에서 발급된 Key를 입력)
String client_secret = "E00C245F457215CD09476ACB0821E3ED851AACD3EC19F9ACB3ED79326B657AAE";
// 단일인증 페이지 호출 시 보냈던 값 동일( SSO 서버에서 검증을 위하여 쓰임 )
String redirect_uri = "https://단일인증시스템Domain/sample/singleAuth.jsp";
// 단일인증 사용자 정보 API URL
String server_api_url = "https://ssodev.kaist.ac.kr/auth/api/single/auth";

// 단일인증 완료 후 SSO 서버로 부터 전달받은 일회성 코드 값
String code = (String) request.getParameter( "code" );

String req_state = (String) request.getParameter( "state" );
String ses_state = (String) session.getAttribute( "state" );
```

```java
// 단일인증 페이지 호출 시 Agent에서 전달한 값과 SSO 서버로 부터 전달 받은 값 비교( CSRF 방지 )
if( req_state.equals( ses_state ) ) {

    String rtnCode = "";
    String user_data = "";

    HashMap<String, String> reqMap = new HashMap<String, String>();
    reqMap.put( "client_id", client_id );
    reqMap.put( "client_secret", client_secret );
    reqMap.put( "code", code );
    reqMap.put( "redirect_uri", redirect_uri );

    if( code != null ) {
        String responseData = httpsConnect( server_api_url, reqMap );

        if( responseData != null && !"".equals( responseData ) ) {

            JSONParser jsonParse = new JSONParser();
            HashMap<String, Object> jsonMap = (HashMap<String, Object>) jsonParse.parse( responseData );

            rtnCode = (String) jsonMap.get( "errorCode" );

            if( rtnCode == null ) {

                String ses_nonce = (String) session.getAttribute( "nonce" );
                String res_nonce = (String) jsonMap.get( "nonce" );

                if( ses_nonce.equals( res_nonce ) ) {

                    user_data = (String) jsonMap.get( "userInfo" );
                    System.out.println( user_data );
                }

            }
        }

    }
```

*** ResponseData에 대한 Json파싱 처리필요**

◎ Response

전송 Data / 전송 Method		Json / POST 방식
Parameter	**Type**	**Parameter Contents**
실패 샘플데이터		
{"errorCode":"ESA004","error":"server_error"}		
errorCode	String	에러코드
error	String	에러코드 내용
성공 샘플데이터		
{"userInfo":{"user_mbtlnum":"010-1223-2221", "user_email":"ssotest@kaist.ac.kr","user_id":"ssotest"},"nonce":"random2"}		
userInfo	JsonString	사용자 정보
※ 사용자 정보는 단일인증 신청서에 명시된 사용자 정보가 전달 됩니다.		

※ API를 통해 전달받은 user_data는 JsonString 형식으로 파싱 하여 로그인 처리에 대한 로직을 구현하시기 바랍니다.

2. 코드 정의

- 다음은 REST API 이용 시 전달받은 코드에 대한 설명입니다.

코드	오류 코드 설명
ESA001	올바르지 않은 요청
ESA002	올바르지 않은 Client 정보
ESA003	올바르지 않은 Redirect URI
ESA004	올바르지 않은 Code
ESA005	Code 사용 유효시간 만료(유효시간 10분)
ESA006	올바르지 않은 사용자 정보
ESA007	등록되지 않은 서버IP
ESA008	필수 파라메터 없음
ESA030	SSO Server Error(관리자에게 문의)